

Cyber Weather Forecast

A local forecast that imports GreyNoise or TAXII 2.1 into ArcadeDB, scores precursor tags against CISA KEV, and shows the graph in D3 with a pinned node, a 1–3 hop filter, and an exposure heat map.

Source plan: cyber_weather_forecast_b0b4bfe9 · Recorded 6 October 2026 · Status: import in progress

WORK REMAINING

IN PROGRESS	Add one importer that loads GreyNoise (local GNQL file or API) or a TAXII 2.1 collection on port 4200, and upserts vertices and edges into ArcadeDB.
PENDING	Define the ArcadeDB graph schema and the 1/2/3-hop neighborhood query used by the API.
PENDING	Add a curated Citrix/CISA timeline and cache the CISA KEV record for CVE-2026-88771 and CVE-2026-88772.
PENDING	Implement Clear / Watch / Advisory / Storm / Named-storm scoring and a deterministic forecast brief from ArcadeDB aggregates.
PENDING	Render the neighborhood in D3 with hop depth 1, 2, or 3 from a node that can be pinned in the UI.

1. What this data can and cannot forecast

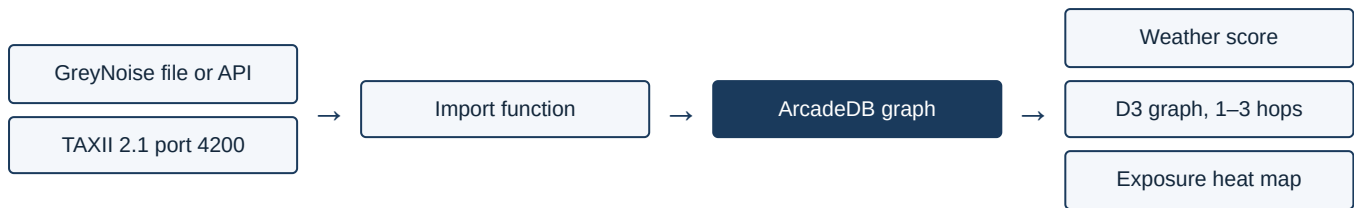
The GreyNoise article [Swarming Against Citrix 0-Day Exploitation](#) is the precursor story. On 24 Sep 2026, 149.104.78.141 hit a Swarm sensor. Behavioral tags fired within seconds (Citrix login-panel crawler, then malicious labels including a CitrixBleed 2 attempt) **before** any CVE-2026-88771 tag existed. Public disclosure and the CVE-specific tag came on 27 Sep. CISA added CVE-2026-88771 and CVE-2026-88772 to KEV the same day.

The file in this folder is a later snapshot, not that first hit:

- Query in request_metadata: cve:CVE-2026-88771 last_seen:30d AND spoofable:false AND classification:malicious (complete, 121 IPs).
- 149.104.78.141 is **not** in the file. Every row is already CVE-tagged and classified malicious.
- 70 IPs were first seen before 24 Sep (reused infrastructure). 49 were first seen on or after disclosure (opportunistic wave).
- Sibling pressure is the strongest precursor still visible: **108/121** also carry CitrixBleed 2 (CVE- 2025-5777), **30/121** the Gateway login-panel crawler, **24/121** the NetScaler scanner, **22/121** all three.
- CVE tag 31c1dc69-e8c5-4cc2-a075-b4e7784befbe session counts: median 10, max 30,000, about 44,080 sessions total.
- Sources cluster on hosting (US 42, Hong Kong 15, Japan 11, Netherlands 10). Sensor **destination** countries (119) are the exposure-pressure layer: US 98 IPs, India 56, Germany 54, Australia 51.

v1 forecasts from this retrospective population plus a curated timeline. A true “before the CVE tag exists” forecast needs a second GreyNoise query that does **not** filter on the new CVE (phase 2).

Figure 1. Import and forecast pipeline



2. Weather model

Score each CVE family with transparent rules, not a trained model.

STATE	RULE
Clear	No vendor crawler, scanner, or sibling exploitation.
Watch	Product crawler or vendor scanner, no CVE tag yet.
Advisory	Crawler or scanner plus a sibling exploited CVE on the same product (CitrixBleed 2 is the template).
Storm	CVE-specific malicious tag, <code>spoofable: false</code> .
Named storm	Storm plus CISA KEV.

For this export the current state is **Named storm**. The agent must say the snapshot is after landfall: the leading signal is reconstructed from co-occurring tags and the article timeline, not observed live on 24 Sep.

Intensity inside Storm uses IP count, CVE `tag_volumes.session_count`, sensor spread, and how many IPs were first seen only after disclosure. “Incoming nature” for this case: unauthenticated edge-gateway command injection, mostly reused hosting infrastructure that already probed CitrixBleed, with a second wave of new IPs after the advisory.

Defensive output only: patch per the Citrix bulletin, preserve evidence before patching (CISA’s guidance), and hunt published indicators. Do not store or display request bodies, payloads, or exploitation steps from `raw_data.http`.

3. Three views

Forecast board

One card per watched CVE. For CVE-2026-88771 show state, confidence, precursor checklist (crawler 30, scanner 24, CitrixBleed 2 108), first-seen split (70 reused / 49 post-disclosure), session intensity, and a dated strip: 10 Sep CVE reserved, 24 Sep behavioral hit, 27 Sep disclosure + KEV + tag deploy, 28 Sep–6 Oct continued `last_seen`.

CTI link analysis

D3 force layout over an ArcadeDB neighborhood. Aggregate graph, not 1,500 raw URL paths.

- Vertices: IP, ASN, organization, source country, JA3 fingerprint, GreyNoise tag, CVE, KEV record, STIX object, public indicator from the article (the exploitation IP, webshell hash, and the two published path indicators as vertices only).
- Edges: observed-with, hosted-by, same-fingerprint, exploits, listed-in-KEV, cited-by, plus STIX `relationship_type` values from TAXII.

- The analyst picks any vertex as the focus. A control sets depth to 1, 2, or 3 hops. The API returns only that neighborhood.
- That focus vertex can be pinned. Pinning sets D3 `fx` and `fy` so the simulation stops moving it; unpinning clears those fields. Other vertices can be pinned the same way without changing the hop origin.
- Default focus is CVE-2026-88771 at 2 hops, with the 22 IPs that carry the crawler, scanner, and CitrixBleed 2 trio highlighted.

Exposure heat map

Two choropleth layers, labeled so they are not confused:

- Source infrastructure: where the malicious IPs geolocate (`metadata.source_country`).
- Sensor pressure: how many of those IPs were seen toward each `destination_country` . This is GreyNoise sensor coverage, not the user's asset inventory. A later overlay can join an internal exposed-NetScaler list; v1 does not invent one. Unit 42's public figure (~50k exposed NetScaler instances on 27 Sep) can be a citation on the card, not a plotted layer.

4. Import

One function, two sources, same ArcadeDB graph. Re-import upserts on a stable key so GreyNoise and TAXII merge instead of duplicating vertices. HTTP request bodies and exploit payloads are dropped before insert.

GreyNoise

`source=greynoise` .

- File mode reads the GNQL export already in this folder (`data[]` plus `request_metadata.query`).
- API mode sends the same class of GNQL to the GreyNoise API when `GREYNOISE_API_KEY` is set. The first live query can repeat the export filter; the precursor query omits the new CVE and keeps malicious, non-spoofable Citrix crawler and CitrixBleed 2 tags.
- Each IP becomes an `Ip` vertex. Tags, CVEs, ASN, organization, source country, and JA3 fingerprints become vertices. Counts and dates stay on the vertex or the edge (`session_count` , `first_seen` , `last_seen`).

TAXII 2.1

`source=taxii` . Default base URL `http://127.0.0.1:4200` , overridable with `TAXII_BASE_URL` .

- Speak TAXII 2.1 only: `Accept: application/taxii+json;version=2.1` .
- `GET /taxii2/` for discovery, then API roots and collections. Import every collection unless `TAXII_COLLECTION_ID` is set.
- Page `GET {api-root}/collections/{id}/objects/` with `next` until the collection is exhausted. Optional `added_after` supports a later incremental run.
- Auth is `Authorization: Bearer` from `TAXII_TOKEN` when the server requires it.
- Map STIX 2.1 into the same graph: `ipv4-addr` and indicator patterns to `Ip` or `Indicator` ; `vulnerability` / `CVE` `external_references` to `Cve` ; `infrastructure` , `malware` , `tool` , `identity` , and `attack-pattern` to typed vertices; STIX `relationship` and `sighting` to edges named by `relationship_type` . Match an existing CVE or IP key so a TAXII vulnerability and a GreyNoise CVE vertex are one node.

CLI shape: `python -m ingest --source greynoise|taxii` . The UI import action calls the same function.

5. Graph store

ArcadeDB is the only database. Run it with Docker (`arcadedata/arcadedb`) on its HTTP port 2480, database `cyberweather` , credentials from the environment. Vertex and edge types are created once. Upsert by a unique key property (`ip:1.2.3.4` , `cve:CVE-2026-88771` , `stix:<id>`).

Neighborhood query, depth limited to 1, 2, or 3:

```
TRAVERSE out(), in()
FROM (SELECT FROM V WHERE key = :focus)
WHILE $depth <= :hops
```

The API returns `{nodes, links}` for D3. Forecast and heat-map numbers are SQL aggregates on the same database, not a second store.

- `data/timeline.yaml` holds the article and CISA dates as curated events (no exploit procedure) and is loaded as `Event` vertices linked to the CVE.
- `model/weather.py` implements the five states and the intensity score from those aggregates.
- FastAPI serves `/import` , `/forecast` , `/graph?focus=&hops=` , `/heatmap` .
- React UI: forecast strip, a D3 force graph (`d3-force` , `d3-drag` , `d3-zoom`), MapLibre choropleth.
- D3 draws the subgraph for the current focus and hop depth. Dragging a vertex pins it (`fx` , `fy`). A pin toggle and a 1 / 2 / 3 hop control sit on the graph. Changing hops refetches from ArcadeDB; pins on vertices still in the result are kept.
- Forecast agent: a function that fills a fixed brief from the model (condition, nature, evidence counts, top source orgs, top destination countries, KEV status, recommended defensive actions). Wire an LLM only as a narrator over that JSON so it cannot invent IPs or dates. v1 can ship the deterministic brief first.

Public KEV join: fetch CISA's known-exploited-vulnerabilities JSON once, match `CVE-2026-88771` / `CVE-2026-88772` , and upsert a `kev` vertex plus a `listed-in-KEV` edge. Cache the feed under `data/` .

6. Phase 2 — scheduled precursors

Reuse the GreyNoise importer on a timer with the precursor GNQL that omits the new CVE. Diff IP and session counts between runs. Escalate Watch to Advisory when sibling-CVE overlap rises, and to Storm when a new CVE tag appears on that cohort. That is how the 24 Sep lead time is reproduced going forward. The seed IP can be looked up directly; it is absent from this export because the query requires the CVE tag and `last_seen` inside 30 days of 6 Oct. TAXII incremental import uses `added_after` from the previous run.

7. Limits to show in the UI

- Filter bias: benign and spoofable sources are excluded; `actor` is `unknown` for all 121 rows; `asn_subnet` is restricted.
- `first_seen` is the IP's GreyNoise lifetime, not the first CVE-2026-88771 packet.
- Destination countries measure sensor aim, not confirmed vulnerable assets.
- 531 distinct CVEs sit on these IPs. Hop depth is capped at 3 so a focus on CVE-2026-88771 stays on this storm; depth 3 from a noisy IP can still pull sibling CVEs into the view.